

Bedienanleitung

Vom Vorfall zum Bericht – Smartphone, USB-Stick, Cloud & Dashboard · Stand 2026-06-21

1 · Was ist IR-Pilot?

Ein **playbook-basiertes Werkzeug für Cyber Incident Responder**. Du wählst Umgebung & Beobachtung, beantwortest einen kurzen Fragebogen, bekommst eine erste Vermutung und ein **geführtes Playbook** – mit Krisenkommunikation, Meldepflichten, Forensik (inkl. *worauf achten*), Beweissicherung **vor** Restore und begleitetem Wiederanlauf. Reines HTML/JS, **offline-fähig**, läuft im Browser des Galaxy Fold 5.

Datenfluss: Endpoints (Boot-Stick / Windows-Sammler) → **App** (zentral) → **Git-Cloud** (cloud/incidents) → **Pages-Dashboard**. Forensik-Rohdaten bleiben am Endpoint, in der Cloud nur Metadaten + Report + Verweise.

2 · Installation

Als App (APK, empfohlen unterwegs)

- APK aufs Handy kopieren, antippen, „unbekannte Quellen“ für den Dateimanager erlauben, installieren.
- Debug-signiert → fürs Sideload gedacht. Cleartext zu lokalen Forensik-Hosts ist in der APK erlaubt.

Als Web-App (PWA, GitHub Pages)

- Seite öffnen, im Browser-Menü „Zum Startbildschirm hinzufügen“ → installierbar, offline.
- **Wichtig:** Die *https*-Pages-App kann lokale *http*-Hosts wegen **Mixed-Content** nicht direkt steuern – dafür die **APK** nutzen oder die App **vom Stick** (*http*) laden.

Vom USB-Stick (offline)

- `index.html` direkt im Browser öffnen (*file://*) – alle Daten sind an Bord.

3 · Start

Schnellstart-Szenarien, generisches Playbook, Assistent und die Einstiege „Geräte/Forensik“, „Forensik-Hosts“, „Live-Dashboard“, „Cloud“.

 **IR-Pilot**

Neuer Vorfall

Gefuehrter Start: Umgebung & Beobachtung waehlen (ohne Technikwissen), Fragebogen beantworten – das Tool schlaegt eine Vermutung vor und baut das Playbook.

► **Gefuehrter Start (Assistent)**

Generisches Playbook starten

 **Geraete & Forensik (nativ)** **Forensik-Hosts (bis 10)**

 **Live-Dashboard** **Cloud & Veroeffentlichen**

Schnellstart (Beispiele)

HOCH

Rechnungs-/IBAN-Manipulation (BEC)

IT · Betrug / E-Mail-Kompromittierung

Versendete Rechnungen kommen mit fremder IBAN an; eingehende PDFs tragen alle dieselbe (auslaendische) IBAN.

KRITISCH

Umspannwerk 300 kV – physischer Einbruch + OT-Manipulationsverdacht

OT/ICS · Energie (KRITIS)

Einbruch ohne Diebstahl/Schaden; Verdacht auf Cyber-Manipulation, ggf. an Schutzgeraeten (Schutzrelais).

KRITISCH

Bahnstellwerk – aktiver Eindringling (Maus bewegt sich)

OT/ICS · Bahn (Safety-kritisch)

Schaltmeister sieht Mauszeiger sich ohne Eingabe bewegen – aktiver Fernzugriff auf einem sicherheitsrelevanten Bedienplatz.

KRITISCH

Ransomware – alles verschluesselt (Kasse

Start-Ansicht

4 · Geführter Vorfall

Der Assistent führt in 4 Schritten: **Umgebung** (≥50 Typen) → **Beobachtung** (Kundensicht) → **Fragebogen** → **Vermutung**. Daraus wird ein Playbook erzeugt.

 IR-Pilot

1. Umgebung

2. Beobachtung

3. Fragebogen

4. Vermutung

1. Welche Umgebung?

Suchen (z.B. Brauerei, Sa

GASTRO

Restaurant / Gaststaette

Hotel / Pension

Baeckerei / Cafe

Catering / Grosskueche

LEBENSMITTEL

Metzgerei / Fleischerei

Brauerei

Weingut / Kellerei

Molkerei

Lebensmittelproduktion

Baeckerei-Kette (mehrere Filialen)

HANDWERK

Schreinerei / Tischlerei

Saegewerk

Metallbau / Schlosserei

Elektrobetrieb

Sanitaer / Heizung (SHK)

Heizungs-/SHK-Betrieb mit eigener Fertigung

Maler / Lackierer

Dachdecker

Kfz-Werkstatt

Druckerei

Goldschmied / Juwelier

Friseur / Kosmetik

INDUSTRIE

Maschinen-/Anlagenbauer

Instandhaltung / Wartungsdienstleister

Das Playbook startet mit dem Gate „Vorfall oder Fehlalarm?“ und führt phasenweise durch Triage, Kommunikation, Forensik, Eindämmung, Bereinigung, Wiederanlauf, Ermittlung, Abschluss.



**Rechnungs-/IBAN-Manipulation
(BEC)**

TLP:AMBER

Playbook

Beweise

IOCs

Komm.

Tools

Geräte

Organisation

Beispiel GmbH

Responder

IR-Team

Einstufung

TLP:AMBER

13/25 Massnahmen · 52 %

Forensische Ableitung

Symptom: IBAN auf dem Quellrechner korrekt, beim Kunden falsch; eingehende Rechnungen einheitlich manipuliert (z.B. nach Litauen).

Hypothesen: (a) **Man-in-the-Mail / BEC** – Postfach kompromittiert, Weiterleitungs-/Posteingangsregeln, Anhaenge werden im Transit getauscht. (b) **Endpoint-Malware (Banking-Trojan)**, die PDFs beim Erzeugen/Senden manipuliert. (c) Kompromittierter Mailserver/Connector. (d) Tippfehler-Domain / Lieferanten kompromittiert.

Beweis-Ableitung: Header & Audit-Logs des Postfachs, Postfachregeln/Weiterleitungen, Vergleich gesendetes Original vs. zugestelltes PDF, Endpoint-Forensik (Autostarts/Prozesse), Mailflow-/Transport-Logs.

Erstbewertung - Vorfall oder Fehlalarm?

1/4

5 · Befunde aus Daten - automatisch im Playbook

Importierte Daten (IOCs, Hosts, Beweise) erscheinen als Panel „ **Befunde aus Daten**“ direkt in der Forensik-Phase – genau dort, wo „Worauf achten (Entscheidung)“ steht. Das Tool entscheidet **bewusst nicht** automatisch Confirm/Refute; du bewertest und setzt die Entscheidung mit einem Tap.



Rechnungs-/IBAN-Manipulation (BEC)

TLP:AMBER

Playbook Beweise IOCs Komm. Tools Geräte

☐ **Datenschutz / DSGVO prüfen (72 h)**

Sind personenbezogene Daten betroffen? Falls ja:
Meldung an die Aufsichtsbehörde binnen 72 h (Art. 33 DSGVO), ggf. Betroffenenbenachrichtigung (Art. 34). DSB einbinden, Frist im Fall notieren.

Vorlage öffnen

Beweissicherung 2/4

 **Befunde aus Daten** 2 IOCs · 2 Beweise

- **iban** LT121000011101001000 Empfängerkonto (Betrug)
- **ip** 203.0.113.66 C2

Beweise: Verdächtige E-Mails (.eml/.msg + Header), M365/Exchange Audit + RegelnDiese Befunde unten gegen „Worauf achten (Entscheidung)“ prüfen und Confirm/Refute setzen. Das Tool entscheidet bewusst nicht automatisch.

☒ **E-Mail-Header & verdächtige Mails sichern**

Vollständige Header der betroffenen Mails exportieren (Tool: **Mail-Header**). Original .eml/.msg sichern, Hash bilden.

+ Beweis erfassen

☐ **PDF-Diff: gesendet vs. zugestellt**

Gesendetes Original-PDF und das beim Kunden angekommene PDF sichern und vergleichen (Metadaten/Producer/Änderungsdatum, IBAN-Stelle).

+ Beweis erfassen

Beweise mit Quelle, Methode, SHA256, Ablage und Flüchtigkeit; Übergaben werden protokolliert.

Ransomware – alles
verschlusselt (Kasse, Buero,
Klima)

TLP:AMBER

Playbook

Beweise

IOCs

Komm.

Tools

Geräte

Beweise & Chain of Custody

+ Neuer Beweis

Ransom-Note + Samples

datei

Quelle

Methode

Kopie

SHA256

e3b0c44298fc1c149afbf4c89

Ablage
(USB/Asservat)

USB:/evidence

Fluechtigkeit

niedrig

Chain of Custody:

· 2026-06-21 11:13 gesichert → IR-Team

Uebergabe protokollieren

Endpoint-Triage-Pakete

datei

Quelle

Methode

Triage-Skript

SHA256

e3b0c44298fc1c149afbf4c89

Ablage
(USB/Asservat)

USB:/evidence

Beweise & Chain of Custody

7 · Bericht & Daten-Import

Incident-Report (Markdown), Timeline-CSV, Lagebericht, Fall-Export (JSON) und Daten-Import (ingest.json / Quick-Paste).
Hier auch „☁ In Cloud veröffentlichen“.

Active Directory – Brute Force
auf Domain-Admin, dann
erfolgreich

TLP:AMBER

Playbook

Beweise

IOCs

Komm.

Tools

Geräte

Bericht & Daten

Markdown kopieren

.md herunterladen

Fall (JSON) exportieren

Timeline CSV

Lagebericht

☁ In Cloud veroeffentlichen

Daten importieren (JSON)

Quick-Paste IOCs

Ingest-Bundles vom Smartphone/Desktop (mobile/desktop-Skripte) hier einlesen.

Incident-Report - Active Directory
- Brute Force auf Domain-Admin,
dann erfolgreich

• **Organisation:** Beispiel GmbH

• **Sektor:** IT · Identitaet / AD-Kompromittierung

• **Responder:** IR-Team

• **Einstufung:** TLP:AMBER

• **Playbook:** Active Directory – Brute Force auf
Domain-Admin, dann erfolgreich

• **Erstellt:** 2026-06-21 11:13

• **Status:** offen

> IDS meldet ~400 fehlgeschlagene Logins
gegen einen Domain-Admin in der Produktion,
danach ein erfolgreicher.

Fortschritt Massnahmen: 14/27 (52 %)

1. Kurzfassung

IDS meldet ~400 fehlgeschlagene Logins gegen

Bericht & Daten

Read-only Triage/Sicherung: Windows/Linux/AD/M365, OT-Capture, Memory, Velociraptor, UAC, Timeline, CyberChef offline. Skript anzeigen, kopieren, herunterladen → am Zielsystem ausführen.



**Ransomware – alles
verschlusselt (Kasse, Buero,
Klima)**

TLP:AMBER

PlaybookBeweiseIOCsKomm.**Tools**Geräte

Forensik-Toolkit

Read-only Triage/Sicherung. Auf den USB-Stick legen, am Zielsystem ausführen.

Windows-Triage

Windows (PowerShell, Admin)

Fluechtige + Schluessel-Artefakte eines Windows-Hosts read-only sichern (Prozesse, Netz, Autostarts, Tasks, Dienste, EventLogs, Prefetch) inkl. Hash-Manifest.

Read-only. NICHT herunterfahren. Fuer RAM-Abbild separates Tool nutzen.

► Skript anzeigen (windows-triage.ps1)

KopierenHerunterladen

Linux-Triage

Linux (bash, root)

Read-only Triage eines Linux-Hosts (Prozesse, Sockets, offene Dateien, Cron, systemd, Logins, Logs) + Hash-Manifest.

Read-only. NICHT neu starten. Fuer RAM ggf. avml/LiME separat.

► Skript anzeigen (linux-triage.sh)

KopierenHerunterladen

Erkennt APK vs. Browser. Capture/Scan/Flash laufen nativ (APK) bzw. via Anleitung/Skript; inkl. „Boot-Stick fernsteuern“.

 **IR-Pilot**

Geraete & Forensik

Browser · web Daten aktualisieren < Start

Im Browser sind privilegierte Aktionen gesperrt (Sandbox). Unten die Skripte/Anleitungen; in der APK laufen sie nativ.

 **Netzwerk-Mitschnitt (WiFi/Ethernet)**

manuell

pcap-Mitschnitt für C2-/OT-Analyse.

Ohne Root am Handy: nur EIGENER Traffic per VpnService (PCAPdroid) – gut für App-/C2-Beacons, NICHT für fremde Hosts. Echter passiver Mitschnitt am Netz (Span-Port/TAP, fremde Hosts) läuft auf dem Boot-Stick (tcpdump, dort root). Alternativ Termux:

Skript: OT-Netzwerk-Capture

Datei auf dem Stick: mobile/phone-capture.sh

 **Boot-Stick fernsteuern (ohne Tastatur)**

manuell

Imaging/Triage/Capture vom Handy-Browser steuern – kein Root am Handy, keine Tastatur am Ziel.

Forensik-Stick im Zielrechner booten, Handy per USB-Ethernet/WLAN verbinden. Der Dienst ir-control.service zeigt URL+Token; im Handy-Browser öffnen. Siehe mobile/hid-keyboard.md. Startet auch über autorun.sh: Datei auf dem Stick: desktop/control-server.py

10 · Forensik-Hosts steuern (bis 10)

Jeder Host = ein Boot-Stick mit `control-server.py`. Adresse + Token hinterlegen oder per „👉 **Auto-Discovery**“ finden lassen. Pro Host: Hosts finden, Wireshark, Image, Win-/Linux-Triage, Manifest; Dateien herunterladen; „↓ **Befunde in Fall**“ speist ingest.json ins aktive Playbook.

 **IR-Pilot**

 **Forensik-Hosts**

< Start

Bis zu 10 gesicherte Forensik-Sticks fernsteuern. Jeder Host = ein Boot-Stick mit `control-server.py`. Adresse + Token werden beim Start auf der Stick-Konsole angezeigt. Alle gesammelten Dateien laufen hier zusammen.

 USB/Netz: Hosts automatisch suchen

Fall oeffnen, um Befunde direkt ins Playbook zu uebernehmen.

Name (z.B. Kasse-PC)

IP:Port (z.B. 10.13.37.1:8080)

Token

+ Host hinzufuegen

Verbunden: 1/10

Kasse-PC

unverbunden

http://10.13.37.1:8080

Verbinden/Aktualisieren

×

/dev/sdb (fuer Image)

Hosts finden

Wireshark

Image

Win-Triage

Linux-Triage

Manifest

Forensik-Hosts (Beispiel-Host)

11 · Cloud & Veröffentlichen

Owner/Repo/Branch sind **vorbelegt** (änderbar). Ergänze einen **fein granularen PAT** (`Contents: write`, nur fürs Daten-Repo) – er bleibt lokal im Browser. „Alle Fälle veröffentlichen“ schreibt Snapshots nach `cloud/incidents/`.

 **IR-Pilot**

 **Cloud & Veroeffentlichen**

< Start

Git als Cloud-Speicher: die App (zentraler Arbeitspunkt) veroeffentlicht Vorfaelle ins Repo, das Pages-Dashboard zeigt sie. Endpoints (Boot-Stick/Windows) liefern die Forensik-Daten zu. Der Token (fein granularer PAT, Contents: write) bleibt lokal im Browser.

Owner	go2dach
Repo	Apk---tests
Branch	claude/fresh-start-v9zow4
Token (PAT)	ghp_... (bleibt lokal)

Speichern

nicht konfiguriert

Dashboard: <https://go2dach.github.io/Apk---tests/dashboard.html>

Veroeffentlichen

Schlanke Snapshots (Kennzahlen, Report, Datei-Verweise auf die Hosts) ins Repo schreiben. Rohdaten bleiben auf den Endpoints.

Alle Faelle veroeffentlichen

Cloud-Index laden

In der Cloud (0)

Noch nichts veroeffentlicht.

12 · Live-Dashboard

In der App: aktive Incidents + verbundene Hosts; Datei-Download nach **PIN 1374**.



Live-Dashboard (App)

Auf Pages (eigenständig, `dashboard.html`): liest `cloud/incidents/index.json`, zeigt alle Vorfälle; Dateien/Reports nach **PIN 1374**.



Aktualisieren

Aktive Incidents (2) Stand: 2026-06-21T12:00:00Z

Ransomware - Kasse dunkel SHK Muster GmbH

kritisch

Status: bestaetigt · 13/20 Massnahmen · 3 Datei(en)

Details ▲

Dateien (auf den Forensik-Hosts gespeichert):

- [intake/Kasse-PC-triage.zip](#) 4.5 MB · Kasse-PC
- [images/kasse.E01](#) 238.42 GB · Stick-1

► Incident-Report

BEC / IBAN-Betrug Kanzlei Beispiel

hoch

Status: suspected · 8/20 Massnahmen · 1 Datei(en)

Details ▼

Beweise & Reports

Entsperrt – Details/Downloads unter „Details“ je Vorfall sichtbar.

Sperren

13 · Boot-Stick & Windows-Sammler

Boot-Stick

- ISO bauen: `build/build-live-iso.sh` (Debian live-build, gparted + Forensik-Tools + App + Skripte).
- Auto-Kopplung: `ir-net.service` (DHCP oder eigene IP `10.13.37.1/24` + Mini-DHCP).
- Fernsteuerung: `ir-control.service` startet automatisch und zeigt URL + Token.
- Ohne Tastatur am Ziel: alles per Handy-Browser über die Stick-IP (siehe `mobile/hid-keyboard.md`).

Windows-Sammler

- `windows/IR-Collect.cmd` doppelklicken (für volle Logs als Admin). Read-only Triage → SHA256 → Upload an den Host.
- Ziel-Host in `ir-target.txt` (base + token) oder beim Start eingeben.
- Erscheint im Dashboard; `ingest.json` per „Befunde in Fall“ direkt ins Playbook.

Ehrlich: Booten vom Stick ist Firmware (BIOS-Boot-Menü), nicht aus der App erzwingbar. Ein Windows-Programm „kalt“ ohne Klick zu starten geht auf Stock-Windows nicht (USB-Autorun deaktiviert). Ab Verbindung übernimmt die App alles automatisch.

14 · Sicherheit & Scope

- Defensives Werkzeug für **autorisierte** Incident Response; Toolkit-Skripte sind read-only.
- Token schützt Host-Zugriff; nur im vertrauenswürdigen Analyse-Netz betreiben.
- Für vertrauliche Fälle ein **privates** Daten-Repo nutzen.
- Rechtliche Schritte/Meldungen mit Recht/DSB/Behörden abstimmen.

IR-Pilot · automatisierte Tests grün: 1635 Logik · 33 UI · 7 Dashboard · Control-Server. Diese Anleitung wurde automatisch aus der laufenden App erzeugt (Screenshots = echte Ansichten).